

Les Pare-feu / Firewalls

Inspiré du cours de Albert Levi

Pourquoi avons-nous besoin de pare-feu?

La **connectivité Internet** est **un besoin** pour la plupart des organisations et des personnes

- ◆ spécialement pour moi

Mais une **connectivité Internet** pratique est **une invitation** pour les **intrus** et les **pirates informatiques**

- ◆ encore un autre exemple de compromis entre commodité et sécurité

Les pare-feu nous offre essentiellement **une option** pour jouer dans le **spectre de ce compromis**

Qu'est-ce qu'un pare-feu?

Moyen efficace de protéger un réseau local ou un réseau de systèmes contre les menaces du monde extérieur

} tout en permettant **simultanément l'accès au monde extérieur** via des réseaux longue distance et l'Internet

Bases du pare-feu

Le pare-feu est inséré entre le réseau interne et Internet (un point d'étranglement)

- ◆ établir une liaison contrôlée et protéger le réseau contre les attaques Internet
 - éloigner les utilisateurs non autorisés
 - imposer des restrictions sur les services réseau; seul le trafic autorisé est autorisé
- ◆ Emplacement de surveillance des événements liés à la sécurité
 - audit, des alarmes peuvent être implémentées
- ◆ certains pare-feu prennent en charge IPSec, de sorte que les VPN peuvent être implémentés pare-feu à pare-feu
- ◆ certains pare-feu prennent en charge NAT (pas si lié à la sécurité)

Discussion ouverte : ne pouvons-nous pas mettre un pare-feu pour chaque station dans le réseau local? Quels sont les avantages et les inconvénients?

Caractéristiques du pare-feu - 1

Objectifs de conception:

- ◆ Tout le trafic de l'intérieur vers l'extérieur et vice versa doit passer par le pare-feu
- ◆ Seul passe le trafic autorisé (défini par la politique de sécurité locale)
- ◆ Le pare-feu lui-même doit être immunisé contre l'intrusion (utilisation d'un système sécurisé doté d'un système d'exploitation sécurisé)

Caractéristiques du pare-feu - 2

Techniques générales de contrôle d'accès

◆ Contrôle de service

- Détermine les **types de services Internet accessibles**
 - Utilisant principalement des numéros de port TCP / UDP

◆ Contrôle de direction

- La **direction du trafic** est **importante** pour la décision
 - Certains services sont ouverts pour le trafic sortant, mais pas pour le trafic entrant (ou vice versa)

◆ Contrôle utilisateur

- Contrôle l'accès à un service **en fonction de l'utilisateur** qui tente d'y accéder
- besoin **d'authentifier les utilisateurs**. C'est facile pour les utilisateurs internes, mais que peut-on faire pour les utilisateurs externes?

◆ Contrôle du comportement

- Contrôle **la façon dont des services particuliers sont utilisés** (par exemple, filtrer les e-mails pour le contrôle du spam)

Plus avancé : **Inspection approfondie des paquets (DPI)**

- Le port 80 (HTTP) est utilisé pour plusieurs services : messagerie Web, médias sociaux, etc.
- DPI consiste à vérifier efficacement le contenu du paquet pour voir quel type d'application il contient

Limitations du pare-feu

ne peut pas se protéger contre les **attaques qui le contournent**

- ◆ exemple typique: appel entrant, appel sortant

ne peut pas se protéger **contre les menaces internes**

- ◆ par exemple un employé mécontent

ne peut pas protéger efficacement **contre le transfert de programmes ou de fichiers infectés par un virus**

- ◆ en raison du trafic intense, de la variété des SEs et d'applications disponibles, et de types de fichiers

Types de pare-feu

- ◆ Pare-feu filtrant les paquets
- ◆ Passerelles de niveau application
- ◆ Passerelles de niveau circuit (pas courantes, donc ignorées)

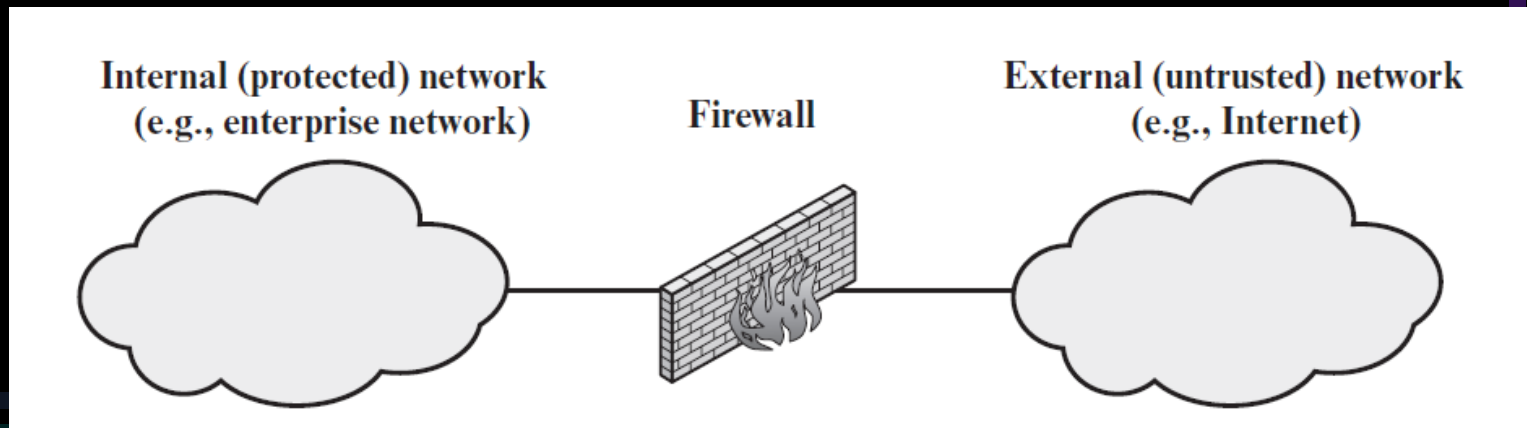
Pare-feu filtrant les paquets

Fondation de tout système de pare-feu

Applique un **ensemble de règles** à chaque **paquet IP** entrant / sortant, puis transfère (autorise) ou rejette (refuse) le paquet (dans les deux sens)

Le filtre de paquets est généralement configuré comme **une liste de règles basées** sur les correspondances aux champs de l'en-tête IP ou TCP
le **contexte n'est pas vérifié**

Deux stratégies par défaut (**autoriser** ou **refuser**)



Pare-feu filtrant les paquets

Les règles de filtrage sont basées sur

- ◆ Adresses IP source et destination
- ◆ Ports source et destination (services) et protocoles de transport (TCP ou UDP)

Les règles sont répertoriées et une correspondance est essayée en commençant par la première règle

- ◆ L'action consiste à autoriser ou à refuser
- ◆ Généralement, la première règle de correspondance est appliquée
- ◆ Si aucune correspondance, la politique par défaut est utilisée
 - La valeur par défaut est soit refuser, soit autoriser

Exemples de filtrage de paquets - 1

Rule	Direction	Source Address	Destination Address	Protocol	Destination Port	Action
A	In	External	Internal	TCP	25	Permit
B	Out	Internal	External	TCP	> 1023	Permit
C	Out	Internal	External	TCP	25	Permit
D	In	External	Internal	TCP	> 1023	Permit
E	Either	Any	Any	Any	Any	Deny

- ◆ A: trafic SMTP entrant autorisé à partir d'adresses IP «externes» particulières vers des adresses IP «internes» particulières
- ◆ B: visant à autoriser les paquets de réponse (problématique)
- ◆ C: Trafic SMTP sortant autorisé à partir d'adresses IP "internes" particulières vers des adresses IP "externes" particulières
- ◆ D: visant à autoriser les paquets de réponse (problématique)
- ◆ E: règle par défaut: refuser (rejeter) le reste
 - Bien sûr, dans un pare-feu normal, il doit y avoir d'autres règles «d'autorisation» pour le bon fonctionnement d'autres services

Exemples de filtrage de paquets - 2

Rule	Direction	Source Address	Destination Address	Protocol	Destination Port	Action
A	In	External	Internal	TCP	25	Permit
B	Out	Internal	External	TCP	> 1023	Permit
C	Out	Internal	External	TCP	25	Permit
D	In	External	Internal	TCP	> 1023	Permit
E	Either	Any	Any	Any	Any	Deny

Les règles B et D posent problème

La règle D autorise non seulement les réponses SMTP entrantes, **mais tout paquet avec un port de destination > 1023**

- Les services malveillants utilisent des ports de destination > 1023

Solution : **ajoutez le port source à l'ensemble de règles** afin de définir l'application pour les paquets de réponse

- Pour les règles B et D, le port source est 25; pour les règles A et C, le port source est > 1023

Exemples de filtrage de paquets - 3

La règle D pose toujours problème après l'ajout de la valeur du port source

- ◆ Le trafic malveillant peut imiter le port source 25 et utiliser un port de destination > 1023
- ◆ Pour résoudre ce problème, nous devons nous assurer que les réponses aux demandes SMTP sont celles à nos demandes; pas un nouveau trafic
 - L'ajout du champ "indicateur TCP" à l'ensemble de règles aide
Si l'indicateur d'acquittement est défini, c'est l'acquittement de notre paquet

Rule	Direction	Source Address	Source Port	Dest Address	Protocol	Dest Port	Flag	Action
D	In	External	25	Internal	TCP	> 1023	ACK	Permit

Une autre aide est l'inspection d'état (diapositive suivante)

Inspection d'état

L'exemple D montre que les ports > 1024 doivent être ouverts

- ◆ non seulement grâce à SMTP, tous les services ont une telle structure
 - les ports < 1024 sont pour les serveurs, un client utilisant un service doit utiliser un numéro de port local compris entre 1024 et 16383

Ainsi, le pare-feu doit **garder une trace** des ports > 1024 **actuellement ouverts**

Un **pare-feu d'inspection d'état** assure **le suivi des connexions TCP sortantes** avec les **numéros de port locaux dans une table** et autorise le trafic entrant pour les ports > 1024 s'il y a une entrée dans cette table (voir la diapositive suivante pour un exemple de table)

Inspection avec état

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	210.9.88.29	80	Established
192.168.1.102	1031	216.32.42.123	80	Established
192.168.1.101	1033	173.66.32.122	25	Established
192.168.1.106	1035	177.231.32.12	79	Established
223.43.21.231	1990	192.168.1.6	80	Established
219.22.123.32	2112	192.168.1.6	80	Established
210.99.212.18	3321	192.168.1.6	80	Established
24.102.32.23	1025	192.168.1.6	80	Established
223.212.212	1046	192.168.1.6	80	Established

Pare-feu filtrant les paquets

Avantages:

- ◆ Simplicité
- ◆ Haute vitesse
- ◆ Transparence aux utilisateurs

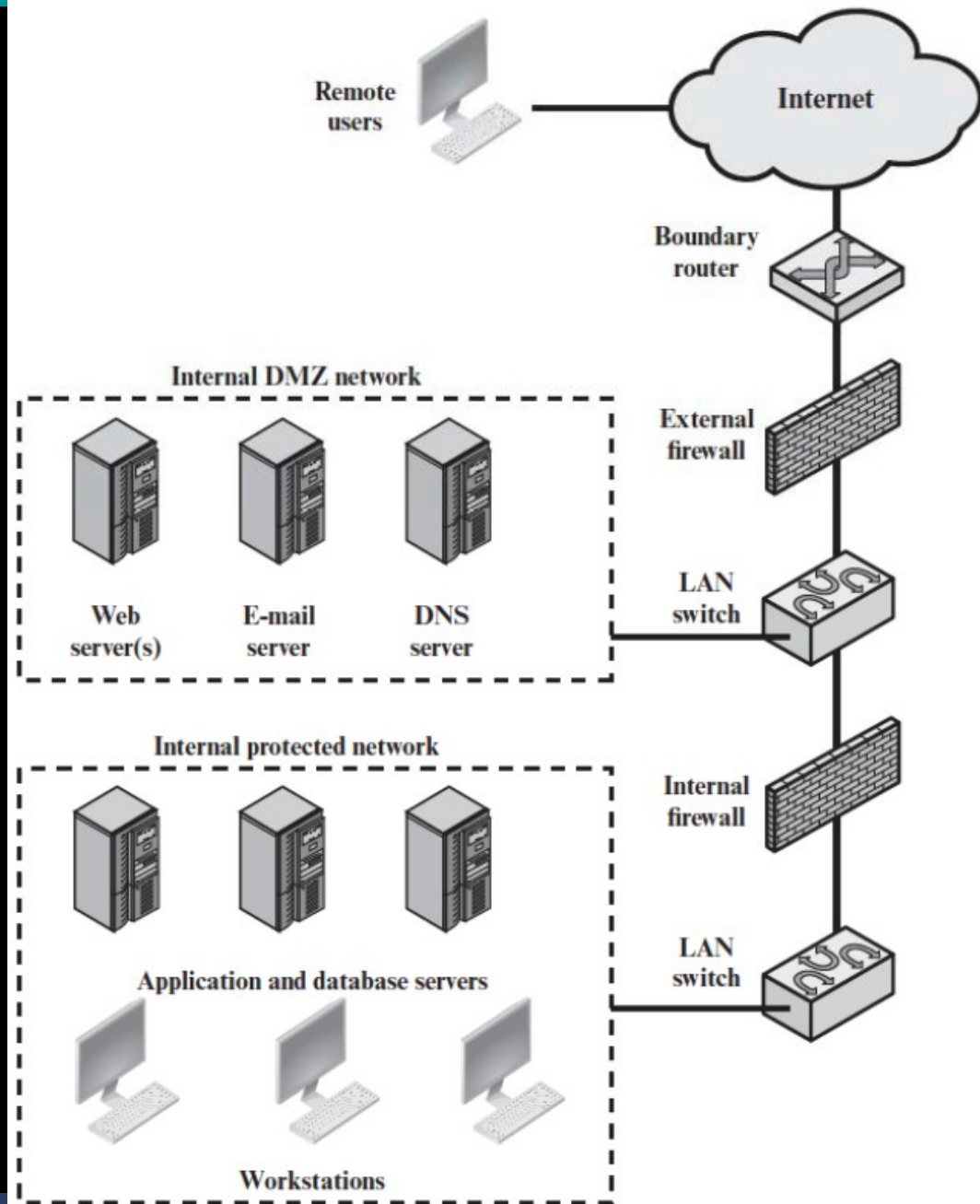
Désavantages

- ◆ Difficulté à configurer les règles de filtrage de paquets
la configuration est sujette aux erreurs
- ◆ un port est ouvert ou fermé; pas de flexibilité de la couche d'application
- ◆ Usurpation d'adresse IP
l'attaquant utilise une adresse IP interne et espère que le paquet pénètre dans le système
contre-mesure: n'acceptez pas les adresses IP internes de l'interface externe

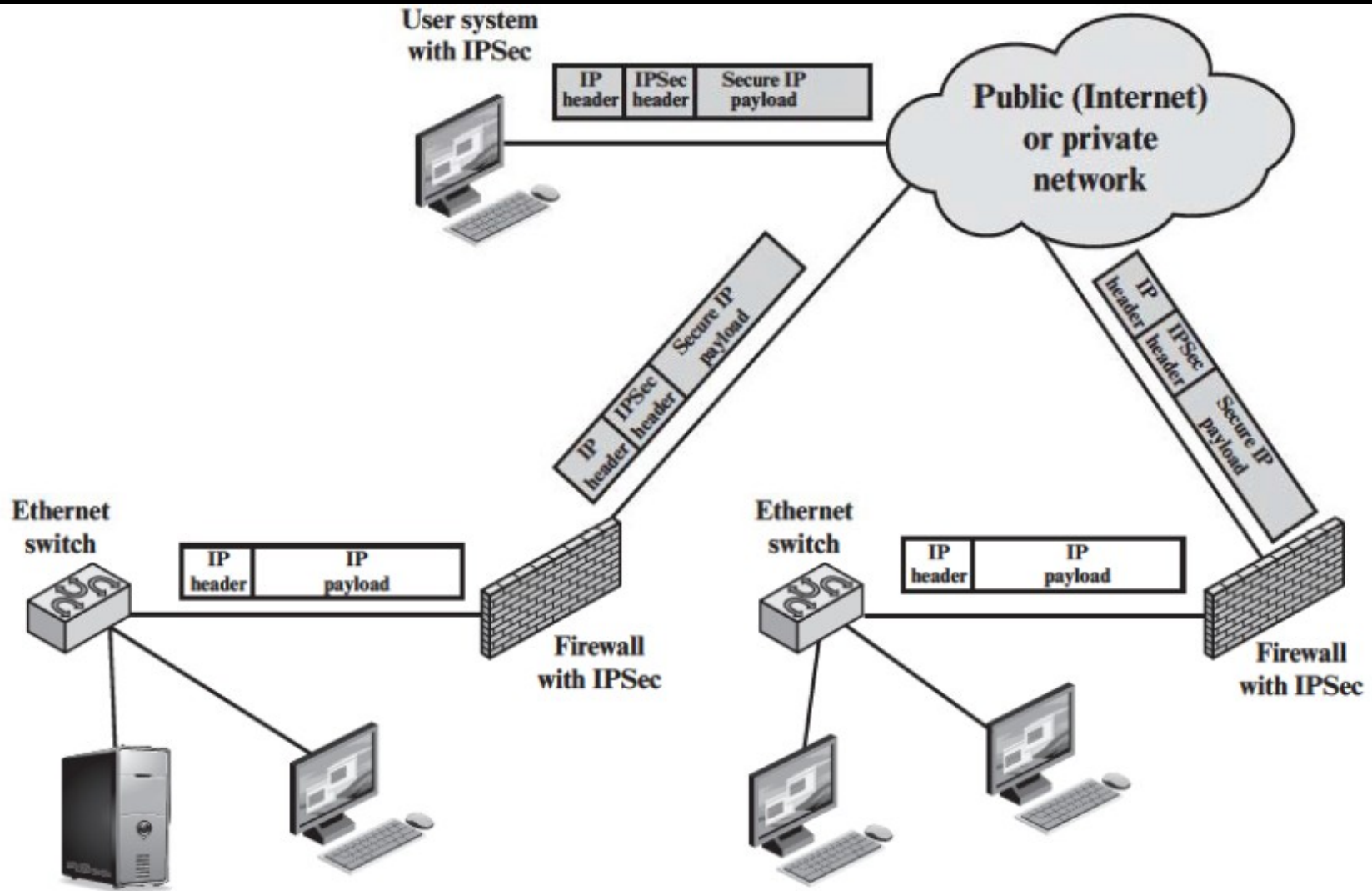
Emplacement et configuration typiques du pare-feu - Systèmes DMZ

DMZ: zone démilitarisée

La partie réseau **ouverte au public** avec moins de projections



Implémentation de VPN dans les pare-feu



Passerelle de niveau application

Une passerelle de niveau application (**serveur proxy**)

- ◆ Agit comme un relais du trafic de niveau application

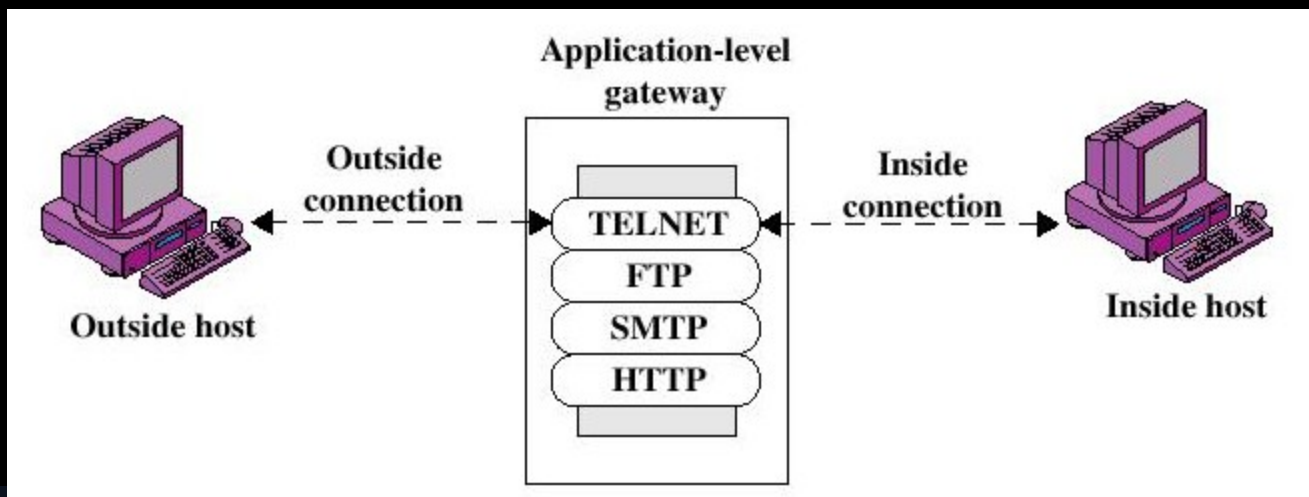
Le proxy obtient des **informations spécifiques à l'application de l'utilisateur** et des **relais vers le serveur**

- ◆ Authentifie éventuellement les utilisateurs

Seules les **applications autorisées** peuvent passer

- ◆ Le traitement basé sur les fonctionnalités est possible

Traitement supplémentaire de chaque connexion



Hôte Bastion

Un système identifié par l'administrateur du pare-feu comme un **point fort critique** de la sécurité du réseau

- ◆ Utilisé dans diverses configurations de pare-feu

L'hôte bastion sert de **plate-forme** pour une **passerelle de niveau application**

- ◆ c'est-à-dire un proxy

Potentiellement exposé à des éléments «hostiles», il est **donc sécurisé** pour résister à cela

- ◆ Système fiable
- ◆ Soigneusement configuré et entretenu

Configurations de pare-feu

En plus de l'utilisation d'une configuration simple d'un seul système

(pare-feu de filtrage de paquets unique) et de systèmes DMZ en deux étapes,

Des configurations plus complexes sont possibles dans lesquelles sont utilisés :

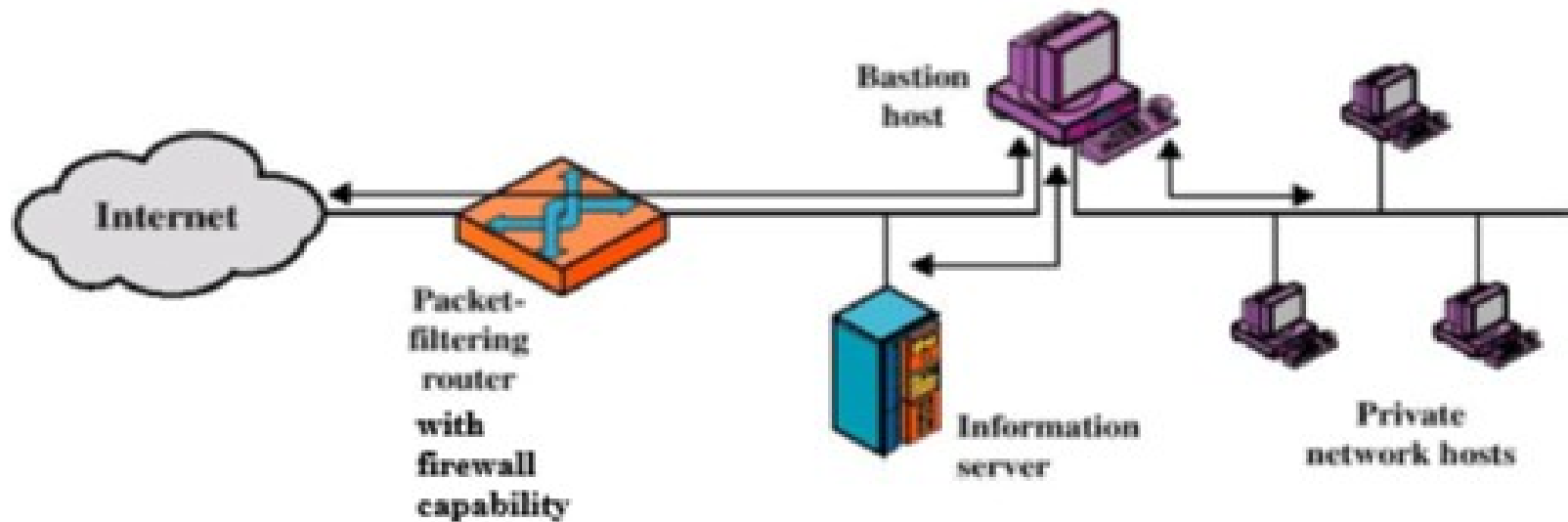
- ◆ **des pare-feu de filtrage de paquets et**
- ◆ **des passerelles au niveau de l'application**

Système de pare-feu d'hôte à double bastion

Seuls les paquets en **provenance de et vers l'hôte bastion** sont **autorisés** à passer par le routeur

L'hôte bastion exécute :

- ◆ des fonctions d'authentification
- ◆ également des fonctions de proxy



Hôte à double bastion

Une **bonne sécurité** pour deux raisons :

- ◆ Cette configuration implémente le filtrage au niveau des paquets et au niveau de l'application
- ◆ Un intrus doit généralement pénétrer dans **deux systèmes distincts** pour accéder au réseau interne

Cette configuration **offre également une flexibilité pour fournir un accès Internet direct** à un serveur d'information publique, par ex. serveur Web

- ◆ en configurant le routeur

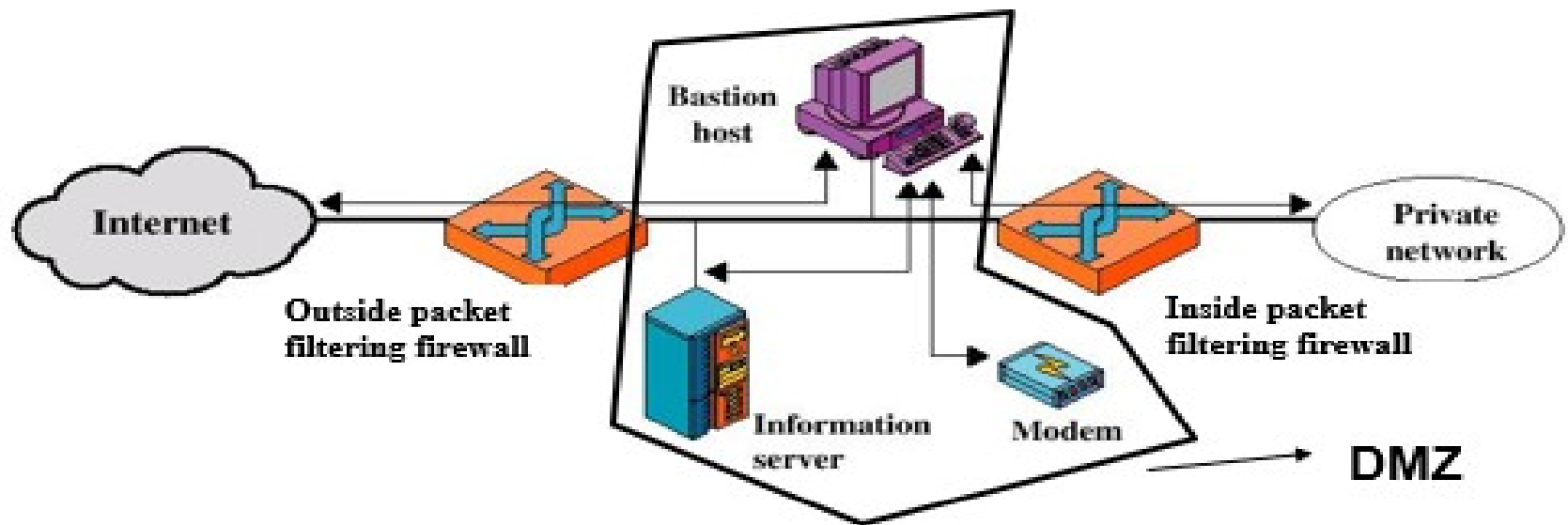
Système de pare-feu de sous-réseau protégé

Plus sécurisé

crée un sous-réseau isolé entre les pare-feu

- ◆ Internet et le réseau privé ont accès à ce sous-réseau
- ◆ Le trafic sur le sous-réseau est bloqué
- ◆ Ce sous-réseau est appelé DMZ (zone démilitarisée)

Le réseau interne est invisible sur Internet



Pare-feu basés sur hôte

Module logiciel pour sécuriser les hôtes individuels

- ◆ filtrer les flux de paquets
- ◆ Disponible en tant que module complémentaire pour de nombreux systèmes d'exploitation

Traditionnellement utilisé sur les serveurs

Avantages :

- ◆ couche supplémentaire de protection du pare-feu organisationnel
- ◆ règles de filtrage adaptées aux besoins spécifiques de l'hôte
- ◆ protection contre les attaques internes / externes

Pare-feu Personnel

contrôle le flux de trafic vers / depuis le PC / poste de travail / appareil portable

pour un usage domestique ou professionnel

module logiciel sur l'appareil

- ◆ routeur / passerelle ADSL

généralement moins complexe que les pare-feu autonomes ou basés sur serveur

rôle principal pour refuser l'accès non autorisé

- ◆ peut également surveiller / détecter / bloquer l'activité des logiciels malveillants